CRISC Domain B – 100 Exam-Style Questions

IT Risk Assessment – Realistic Scenario Practice (Answer on the Next Slide)

CRISC Mastery Series

October 21, 2026

Instructions

How to Use This Deck

Think like a risk practitioner: business objectives first, owners decide, assess before acting. Read for BEST, FIRST and MOST. Answer on the slide after each question.

Outline

1. Risk Identification
2. Risk Analysis
3. Risk Evaluation and Appetite
4. Risk Response
5. Controls
6. Monitoring and Reporting
7. BIA, Recovery and Third Parties
8. Governance and Risk Culture

Q1: Cloud Migration

Question

A company plans to migrate its core applications to a public cloud. What should the risk practitioner do FIRST?

- A. Select cloud security controls
- B. Review the provider's SOC report
- C. Understand the business objectives and scope of the migration
- D. Update the disaster recovery plan

Q1: Explanation

Correct Answer: C

- Risk only has meaning relative to business objectives
- Scope tells you which assets and processes are affected
- Controls and assurance reviews come after the risk context is known
- Starting with controls skips the purpose of the change

Critical Trap

Start with objectives and scope, not controls.

Q2: Emerging Risks

Question

Which is the BEST source for identifying EMERGING IT risks?

- **A** Prior-year audit reports
- **B** Industry threat intelligence and environmental scanning
- **C** The existing risk register
- **D** Incident logs from the last quarter

Q2: Explanation

Correct Answer: B

- Emerging risks have little or no history
- Forward-looking sources show trends before they become incidents
- Audit reports, registers and incident logs show known past issues

Critical Trap

Historical sources cannot identify emerging risks.

Q3: Scenario Development

Question

Risk scenarios are MOST useful when they are developed:

- **A** With input from both business and IT stakeholders
- **B** From vulnerability scan results only
- **C** By the IT department alone
- **D** By external consultants without staff input

Q3: Explanation

Correct Answer: A

- Business owners understand impact
- IT understands threats and vulnerabilities
- Combined input produces realistic, relevant scenarios
- One-sided input leaves blind spots

Critical Trap

Scenarios need both business and technical views.

Q4: Risk Versus Vulnerability

Question

Which of the following BEST describes a RISK (rather than a threat or vulnerability)?

- (A) A criminal group targeting retailers
- (B) A weak password policy
- (C) An unpatched server
- (D) Customer data could be stolen through an unpatched server, resulting in regulatory fines

Q4: Explanation

Correct Answer: D

- A risk links a cause, an event and a business consequence
- An unpatched server and a weak policy are vulnerabilities
- A criminal group is a threat source

Critical Trap

Risk is cause plus event plus consequence.

Q5: New Regulation

Question

A new data protection regulation is announced. What should the risk practitioner do FIRST?

- **A** Notify all customers
- **B** Rewrite all policies
- **C** Determine whether and how the regulation applies to the organization
- **D** Implement new controls immediately

Q5: Explanation

Correct Answer: C

- Applicability must be confirmed before any response
- Scope determines the gap analysis
- Controls and policy changes follow the assessment

Critical Trap

Assess applicability before acting.

Q6: Acquisition

Question

An organization acquires a company and plans to connect the two networks next week. What is the BEST action for the risk practitioner?

- A. Assess the risks of the acquired environment before connecting
- B. Rely on the seller extquotesingle s assurances
- C. Wait for the next annual risk assessment
- D. Connect and monitor traffic afterward

Q6: Explanation

Correct Answer: A

- Connecting networks can import unknown risks
- Assessment should happen before the connection
- Monitoring after the fact is reactive
- Seller assurances are not independent evidence

Critical Trap

Assess before you connect.

Q7: Vulnerability Scan Results

Question

A scan reports 3,000 vulnerabilities. What should the risk practitioner do NEXT?

- **A** Rank them by age
- **B** Patch everything immediately
- **C** Report the total count to the board
- **D** Relate the findings to critical assets, threats and business impact

Q7: Explanation

Correct Answer: D

- Raw counts do not measure risk
- Business impact and threat likelihood decide priority
- Blanket patching is rarely feasible or necessary

Critical Trap

Findings become risks only when tied to business impact.

Q8: Delphi Technique

Question

Which technique BEST obtains unbiased expert consensus when strong personalities may dominate meetings?

- (A) Walkthrough meeting
- (B) Checklist review
- (C) Open brainstorming
- (D) Delphi technique

Q8: Explanation

Correct Answer: D

- Experts respond anonymously in rounds
- Feedback is shared without attribution
- This reduces dominance and groupthink

Critical Trap

Anonymity reduces dominant-voice bias.

Q9: Shadow IT

Question

Business units are using unapproved cloud tools. What should the risk practitioner do FIRST?

- A. Block all unapproved tools immediately
- B. Record it as accepted
- C. Determine what data and processes are involved and assess the risk
- D. Discipline the users

Q9: Explanation

Correct Answer: C

- Understand exposure before reacting
- Blocking may disrupt legitimate business needs
- Acceptance requires an assessment and an authorized owner

Critical Trap

Assess before blocking or accepting.

Q10: Incident Lessons

Question

After a major incident, how should risk identification be updated?

- **A** Remove related risks because they materialized
- **B** Only update the incident log
- **C** No change: the incident is closed
- **D** Use root-cause analysis to revise scenarios and the risk register

Q10: Explanation

Correct Answer: D

- Incidents reveal gaps in earlier assessments
- Root cause shows which scenarios or controls were wrong
- The register should reflect what was learned

Critical Trap

Incidents are inputs to risk identification.

Q11: Incomplete Asset Inventory

Question

What is the MOST significant effect of an incomplete asset inventory on risk assessment?

- A. Reports look less professional
- B. Risks to unknown assets are not identified or assessed
- C. Control testing costs more
- D. Assessments take longer

Q11: Explanation

Correct Answer: B

- You cannot assess what you do not know exists
- Unknown assets may be critical
- Exposure is understated

Critical Trap

Unknown assets mean unassessed risk.

Q12: Duplicate Risks

Question

Two departments logged the same risk with different ratings. What is the BEST action?

- A. Keep both entries
- B. Use the higher rating
- C. Remove the lower-rated entry
- D. Consolidate, reassess using common criteria and assign one owner

Q12: Explanation

Correct Answer: D

- Duplicates cause confusion and conflicting actions
- Common criteria give a consistent rating
- A single owner provides accountability

Critical Trap

One risk, one owner, one rating.

Q13: Top-Down and Bottom-Up

Question

Using both top-down and bottom-up risk identification BEST helps to:

- A. Reduce the number of risks
- B. Guarantee completeness
- C. Link strategic risks with operational detail
- D. Remove the need for workshops

Q13: Explanation

Correct Answer: C

- Top-down starts from objectives
- Bottom-up starts from processes and assets
- Together they connect strategy to operations
- No method guarantees completeness

Critical Trap

Combined approaches improve coverage, not completeness.

Q14: Scenario Relevance

Question

Which element MOST helps decide whether a risk scenario matters to the business?

- A. The seniority of the analyst
- B. Its potential effect on business objectives
- C. The technology involved
- D. The number of systems affected

Q14: Explanation

Correct Answer: B

- Risk is about effect on objectives
- Technology details do not show business relevance
- Objective impact drives prioritization

Critical Trap

No objective at stake means no business risk.

Q15: Project Initiation

Question

When should risk identification for a new IT project begin?

- A After the first incident
- B At project initiation and continue throughout
- C After testing is complete
- D At go-live

Q15: Explanation

Correct Answer: B

- Early identification allows cheaper treatment
- Risks change as the project evolves
- Late identification limits options

Critical Trap

Identify early, then keep going.

Q16: Qualitative Approach

Question

Reliable historical loss data is NOT available. Which approach is MOST appropriate?

- **A** Using a competitor extquotesingle s data as exact values
- **B** A quantitative assessment using assumed numbers, undisclosed
- **C** Skipping the assessment
- **D** A qualitative assessment that clearly states its limitations

Q16: Explanation

Correct Answer: D

- Qualitative methods suit limited data
- Limitations must be disclosed
- Undisclosed assumptions give false precision

Critical Trap

Do not fake precision.

Q17: Risk Formula

Question

Risk is BEST expressed as a function of:

A. Vulnerability and control
B. Threat and asset
C. Cost and benefit
D. Likelihood and impact

Q17: Explanation

Correct Answer: D

- Likelihood is how probable an event is
- Impact is the consequence if it occurs
- Together they express risk magnitude

Critical Trap

Risk equals likelihood and impact.

Q18: Inherent Risk

Question

Inherent risk is the risk:

- **A** Before considering existing controls
- **B** After treatment is complete
- **C** Accepted by management
- **D** After controls are applied

Q18: Explanation

Correct Answer: A

- It shows exposure without controls
- It reveals how much controls are carrying
- Residual risk comes after controls

Critical Trap

Inherent means before controls.

Q19: Residual Risk

Question

Residual risk is BEST described as:

A. Risk transferred to an insurer
B. Total risk without controls
C. Risk that has been eliminated
D. The risk remaining after controls and responses are applied

Q19: Explanation

Correct Answer: D

- It is what remains after treatment
- It is compared with appetite
- It is never exactly zero

Critical Trap

Residual is after controls.

Q20: Impact Driver

Question

Which factor MOST influences the impact rating of an IT asset failure?

- **A** Criticality of the business processes it supports
- **B** Purchase price of the asset
- **C** Age of the hardware
- **D** Vendor name

Q20: Explanation

Correct Answer: A

- Impact is measured by business consequence
- Critical processes mean higher impact
- Cost and age are weak proxies

Critical Trap

Business criticality drives impact.

Q21: Outdated Data

Question

Loss data is 5 years old and the business has changed significantly. What should the risk practitioner do?

- A. Use the data unchanged
- B. Use only industry averages
- C. Discard the analysis entirely
- D. Adjust the analysis using current threat information and expert judgment

Q21: Explanation

Correct Answer: D

- Old data may not reflect current risk
- Adjust for current conditions
- Data is still a useful starting point

Critical Trap

Old data is not automatically relevant data.

Q22: Inconsistent Ratings

Question

Different teams rate similar risks inconsistently. What is the BEST solution?

- (A) Let each team choose its own scales
- (B) Use only the highest ratings
- (C) Reduce the number of teams
- (D) A standardized methodology with defined likelihood and impact scales

Q22: Explanation

Correct Answer: D

- Common definitions give comparable results
- Scales need clear descriptions
- Calibration workshops help consistency

Critical Trap

Standardize scales to get comparable ratings.

Q23: Sensitivity Analysis

Question

Which technique BEST shows how changes in assumptions affect risk results?

- A Sensitivity analysis
- B Walkthrough
- C Control self-assessment
- D Gap analysis

Q23: Explanation

Correct Answer: A

- It varies inputs to see the effect on results
- It identifies assumptions that matter most
- It helps judge reliability of an analysis

Critical Trap

Test assumptions with sensitivity analysis.

Q24: Annual Loss Expectancy

Question

An asset is worth $500K, the exposure factor is 40%, and the event is expected once every 2 years. What is the annualized loss expectancy?

- A $250K
- B $100K
- C $50K
- D $200K

Q24: Explanation

Correct Answer: B

- SLE $= 500K \times 40\% = \$200K$
- ARO $= 0.5$ per year
- ALE $= 200K \times 0.5 = \$100K$
- \$200K is the single loss expectancy

Critical Trap

ALE equals SLE times ARO.

Q25: Low Likelihood High Impact

Question

A risk has very low likelihood but catastrophic impact. What is the BEST view?

- A. Do not dismiss it; consider contingency planning or transfer
- B. Avoid it by shutting down operations
- C. Accept it without review
- D. Ignore it because likelihood is low

Q25: Explanation

Correct Answer: A

- Severe impact can threaten survival
- Contingency and insurance suit rare severe events
- Low likelihood is not zero

Critical Trap

Rare does not mean unimportant.

Q26: Input Quality

Question

The reliability of a risk analysis depends MOST on:

A. The number of analysts
B. The complexity of the model
C. The length of the report
D. The quality of the data and assumptions used

Q26: Explanation

Correct Answer: D

- Poor input produces poor output
- Assumptions should be documented and validated
- Complex models do not fix weak data

Critical Trap

Garbage in, garbage out.

Q27: Aggregated View

Question

Why is aggregating related risks useful?

- A. It lowers total risk
- B. It shows combined exposure that individual ratings may hide
- C. It removes the need for risk owners
- D. It speeds up control testing

Q27: Explanation

Correct Answer: B

- Related risks can share causes
- Combined exposure can exceed appetite even if each item is small
- Aggregation supports better decisions

Critical Trap

Many small related risks can add up.

Q28: Equal Scores

Question

Two risks have the same score. What is the BEST way to prioritize them?

- A Treat them as equal
- B Choose alphabetically
- C Consider business impact on critical objectives and how quickly each could materialize
- D Fix the cheaper one first

Q28: Explanation

Correct Answer: C

- Same score can hide different profiles
- Impact on key objectives matters
- Speed of onset affects response time

Critical Trap

Same score does not mean same priority.

Q29: Control Effectiveness

Question

Control effectiveness is MOST directly used to determine:

- (A) Risk appetite
- (B) Asset value
- (C) Inherent risk
- (D) Residual risk

Q29: Explanation

Correct Answer: D

- Effective controls reduce inherent risk
- The result is residual risk
- Appetite is set by leadership

Critical Trap

Controls move you from inherent to residual.

Q30: Complacency

Question

A team rates a risk low because nothing has happened for years. This reflects:

- (A) Excessive control
- (B) A valid conclusion
- (C) Appropriate conservatism
- (D) Complacency from past experience; current threats should be considered

Q30: Explanation

Correct Answer: D

- Absence of incidents is not evidence of low risk
- Threats and business change over time
- Use current intelligence

Critical Trap

Nothing happened is not a risk rating.

Q31: Setting Appetite

Question

Who is ultimately responsible for setting risk appetite?

- A. The risk practitioner
- B. Internal audit
- C. The board and senior management
- D. The IT manager

Q31: Explanation

Correct Answer: C

- Appetite reflects strategy and risk-taking intent
- Leadership is accountable for it
- Others advise and implement

Critical Trap

Leadership sets appetite.

Q32: Above Appetite

Question

A risk exceeds appetite. What should the risk practitioner do FIRST?

- (A) Lower the rating
- (B) Inform the risk owner and escalate according to governance
- (C) Implement a control immediately
- (D) Accept the risk

Q32: Explanation

Correct Answer: B

- The owner must decide the response
- Escalation follows defined thresholds
- The practitioner advises and does not decide

Critical Trap

Escalate; do not decide for the owner.

Q33: Tolerance

Question

Risk tolerance is BEST described as:

- (A) The control budget
- (B) Total risk faced
- (C) The maximum loss the organization can survive
- (D) The acceptable deviation from risk appetite

Q33: Explanation

Correct Answer: D

- Appetite is the desired level
- Tolerance is the allowed variation around it
- Capacity is the survival limit

Critical Trap

Tolerance is the permitted variance.

Q34: Residual Above Appetite

Question

After treatment, residual risk still exceeds appetite. What is the BEST next step?

- A. Close the risk
- B. Escalate for further treatment or formal acceptance by the appropriate authority
- C. Lower the rating
- D. Ignore it until the next review

Q34: Explanation

Correct Answer: B

- Residual above appetite needs a decision
- Options are more treatment or authorized acceptance
- Quiet closure hides exposure

Critical Trap

Above appetite needs an explicit decision.

Q35: Acceptance Authority

Question

Who should accept a residual IT risk?

- A. The vendor
- B. The CISO by default
- C. The risk practitioner
- D. The business owner with authority over the affected process

Q35: Explanation

Correct Answer: D

- The owner bears the consequences
- Authority must match the size of the risk
- The practitioner informs the decision

Critical Trap

Business owners accept business risk.

Q36: Measurable Appetite

Question

The appetite statement is general and has no measures. What is the BEST improvement?

- (A) Remove it
- (B) Let each business unit invent its own
- (C) Define measurable thresholds and link them to KRIs
- (D) Make the statement longer

Q36: Explanation

Correct Answer: C

- Measures make breaches visible
- KRIs track exposure against thresholds
- Vague statements cannot guide decisions

Critical Trap

If it cannot be measured, it cannot be managed.

Q37: Risk Capacity

Question

Risk capacity is:

- **A** The desired level of risk
- **B** The budget for controls
- **C** The maximum risk the organization can bear without threatening survival or objectives
- **D** The acceptable variation from appetite

Q37: Explanation

Correct Answer: C

- Capacity is an upper limit
- Appetite and tolerance sit below it
- Exceeding it is existential

Critical Trap

Capacity is the ceiling.

Q38: Project Approval

Question

How should risk be considered when approving a new project?

- **A** Compare expected risk with risk appetite
- **B** Approve if no incidents occurred last year
- **C** Approve if IT agrees
- **D** Approve if cost is within budget

Q38: Explanation

Correct Answer: A

- Decisions should be risk-informed
- Appetite provides the reference point
- Budget and IT agreement do not show risk acceptability

Critical Trap

Use appetite as the yardstick.

Q39: Rating Disagreement

Question

IT and the business disagree about an impact rating. What is the BEST approach?

- A. IT decides
- B. Escalate every disagreement to the board
- C. Use the average of both
- D. Use agreed criteria, with the business owner validating impact

Q39: Explanation

Correct Answer: D

- The business understands impact
- Agreed criteria reduce subjectivity
- Escalation is for unresolved or material issues

Critical Trap

Impact belongs to the business.

Q40: Accepted Risk

Question

A low risk has been accepted. What should happen afterward?

- (A) Transfer it
- (B) Remove it from the register
- (C) Document it and monitor for changes
- (D) Forget it

Q40: Explanation

Correct Answer: C

- Acceptance is a documented decision
- Conditions can change
- Monitoring confirms it stays acceptable

Critical Trap

Accepted does not mean forgotten.

Q41: Insurance

Question

Buying cyber insurance is an example of risk:

- (A) Transfer
- (B) Mitigation
- (C) Acceptance
- (D) Avoidance

Q41: Explanation

Correct Answer: A

- Insurance shifts financial consequence
- It does not remove the risk
- Accountability remains with the organization

Critical Trap

Insurance shifts financial loss only.

Q42: Cost Exceeds Benefit

Question

A control would cost $100K per year to protect against an ALE of $40K. What is the BEST response?

- **A** Avoid the process entirely
- **B** Accept the risk after documentation, or look for a cheaper control
- **C** Implement it anyway
- **D** Ignore the risk silently

Q42: Explanation

Correct Answer: B

- Cost exceeds benefit
- Acceptance must be documented and authorized
- A cheaper control may exist

Critical Trap

Do not spend more than the risk is worth.

Q43: Outsourcing

Question

When processing is outsourced, accountability for the associated risk:

- **A** Remains with the organization
- **B** Moves to the regulator
- **C** Moves to the vendor
- **D** Is shared equally by contract

Q43: Explanation

Correct Answer: A

- Responsibility for tasks can be delegated
- Accountability cannot be outsourced
- Oversight remains necessary

Critical Trap

You can outsource work, not accountability.

Q44: Response Selection

Question

Risk response selection should BEST be driven by:

- A. Cost-benefit and alignment with risk appetite
- B. The cheapest option
- C. Technology preference
- D. What peers do

Q44: Explanation

Correct Answer: A

- Responses must bring risk within appetite
- Cost must be justified by benefit
- Peers extquotesingle practices may differ in context

Critical Trap

Fit the response to appetite and cost.

Q45: Avoidance

Question

Which is an example of risk avoidance?

A. Documenting acceptance
B. Adding a firewall
C. Discontinuing a service that creates unacceptable risk
D. Buying insurance

Q45: Explanation

Correct Answer: C

- Avoidance removes the activity
- Insurance is transfer
- A firewall is mitigation

Critical Trap

Avoidance stops the activity.

Q46: Preventive Control

Question

Which is a PREVENTIVE control?

- A. Restoring from backup
- B. Access control that blocks unauthorized logins
- C. Incident response procedure
- D. Review of system logs

Q46: Explanation

Correct Answer: B

- Preventive controls stop events
- Log review is detective
- Backup restore is corrective

Critical Trap

Preventive stops it before it happens.

Q47: Detective Control

Question

Which is a DETECTIVE control?

- A Data encryption
- B Firewall rules
- C Segregation of duties
- D Review of system logs for anomalies

Q47: Explanation

Correct Answer: D

- Detective controls identify events after they occur
- Firewalls and encryption are preventive
- Segregation of duties is preventive

Critical Trap

Detective finds, it does not stop.

Q48: Compensating Control

Question

Segregation of duties is impractical in a small team. Which is the BEST compensating control?

- A. Disabling logging
- B. Sharing passwords to speed work
- C. Annual rotation only
- D. Independent management review of transactions

Q48: Explanation

Correct Answer: D

- Compensating controls reduce the same risk another way
- Independent review detects misuse
- It must be as effective as the original control

Critical Trap

Compensate for the same risk, not just any risk.

Q49: Response Approval

Question

Who should approve a risk response plan?

- A. The risk practitioner
- B. The external auditor
- C. The help desk
- D. The risk owner

Q49: Explanation

Correct Answer: D

- The owner is accountable for the risk
- The practitioner advises
- Auditors provide independent assurance only

Critical Trap

The owner approves the response.

Q50: After Implementation

Question

After a new control is implemented, what should the risk practitioner do?

- (A) Stop monitoring
- (B) Close all related risks
- (C) Assume the risk is zero
- (D) Validate its effectiveness and reassess residual risk

Q50: Explanation

Correct Answer: D

- Implementation does not prove effectiveness
- Residual risk must be re-evaluated
- Monitoring continues

Critical Trap

Implemented does not mean effective.

Q51: Verbal Acceptance

Question

A manager accepted a risk verbally. What should the risk practitioner do?

- (A) Implement a control without approval
- (B) Treat verbal acceptance as sufficient
- (C) Ensure formal, documented acceptance according to policy
- (D) Delete the risk

Q51: Explanation

Correct Answer: C

- Acceptance must be traceable
- Documentation shows informed decision-making
- Policy defines authority and format

Critical Trap

Undocumented acceptance is not defensible.

Q52: Vendor Refuses Assurance

Question

A critical vendor refuses to provide assurance reports. What is the BEST action?

- **A** Escalate to the risk owner and seek alternative assurance or compensating controls
- **B** Accept the risk automatically
- **C** Proceed without review
- **D** Terminate the vendor immediately

Q52: Explanation

Correct Answer: A

- Lack of assurance means unknown risk
- The owner decides how to respond
- Alternatives may include contractual rights or added controls

Critical Trap

No assurance means escalate, not ignore.

Q53: Temporary Exception

Question

A temporary exception to policy is requested. Which condition is BEST?

- A. Open-ended with no review
- B. Time-bound, formally approved and supported by compensating controls
- C. Verbally approved
- D. Approved without compensating controls

Q53: Explanation

Correct Answer: B

- Exceptions should expire
- Approval creates accountability
- Compensating controls limit exposure

Critical Trap

Exceptions must be temporary and controlled.

Q54: Response Underperforms

Question

A risk response is not reducing risk as expected. What should be done?

- A. Stop monitoring the risk
- B. Continue unchanged
- C. Reassess the risk and revise the response
- D. Accept the risk without analysis

Q54: Explanation

Correct Answer: C

- The assumed benefit was not achieved
- Reassessment shows true residual risk
- Revision aligns response with appetite

Critical Trap

A failing response needs rework.

Q55: Mitigation Fit

Question

A risk exceeds appetite and an affordable, effective control exists. Which response BEST fits?

- (A) Mitigate by implementing the control
- (B) Accept the risk
- (C) Transfer only, with no other action
- (D) Ignore the risk

Q55: Explanation

Correct Answer: A

- Risk is above appetite
- A cost-effective control is available
- Mitigation brings the risk within appetite

Critical Trap

Use available effective controls to meet appetite.

Q56: Design Versus Operation

Question

A control is well designed but staff do not perform it. This is a deficiency in:

- A Design
- B Operating effectiveness
- C Risk appetite
- D Scope

Q56: Explanation

Correct Answer: B

- Design is correct
- Failure is in execution
- Remediation focuses on training or process

Critical Trap

Good design does not guarantee operation.

Q57: Defense in Depth

Question

Defense in depth BEST means:

- A One very strong control
- B More policies
- C Perimeter controls only
- D Multiple layered controls so one failure does not expose assets

Q57: Explanation

Correct Answer: D

- Layers provide redundancy
- No single failure exposes the asset
- Layers should not share the same weakness

Critical Trap

Layers beat a single point of defense.

Q58: Control Owner

Question

The control owner is responsible for:

- **A** Independently auditing the control
- **B** Accepting residual risk
- **C** Setting risk appetite
- **D** Implementing and operating the control

Q58: Explanation

Correct Answer: D

- Control owners run the control
- Risk owners accept risk
- Audit is independent

Critical Trap

Control owner operates; risk owner accepts.

Q59: Corrective Control

Question

Restoring systems from backup after an incident is primarily a:

- (A) Deterrent control
- (B) Corrective control
- (C) Detective control
- (D) Preventive control

Q59: Explanation

Correct Answer: B

- Corrective controls limit damage and restore
- Preventive controls stop events
- Detective controls identify events

Critical Trap

Restoring is corrective.

Q60: Independent Testing

Question

Which testing provides the MOST objective assurance of control effectiveness?

- A. Verbal confirmation
- B. Manager attestation without evidence
- C. A self-test by the control owner
- D. Independent testing by a party not responsible for the control

Q60: Explanation

Correct Answer: D

- Independence reduces bias
- Evidence supports conclusions
- Self-assessment is useful but less objective

Critical Trap

Independence gives objectivity.

Q61: Control Gap

Question

A control gap is discovered. What should the risk practitioner do FIRST?

- A. Report to regulators
- B. Implement a control immediately
- C. Assess the risk exposure resulting from the gap
- D. Close the gap by changing policy

Q61: Explanation

Correct Answer: C

- Impact of the gap determines urgency
- Response should be proportionate
- Assessment comes before remediation

Critical Trap

Assess the exposure, then respond.

Q62: Automated Controls

Question

Compared with manual controls, automated controls are generally:

- A. Immune to failure
- B. Not requiring testing
- C. More consistent, with less risk of human error
- D. Always cheaper

Q62: Explanation

Correct Answer: C

- Automation applies rules consistently
- They can still be misconfigured
- They need testing and change control

Critical Trap

Automated is consistent, not infallible.

Q63: Control Selection

Question

Controls should be selected BEST based on:

A. Risk assessment results and risk appetite
B. Vendor recommendations
C. What peers use
D. Cost alone

Q63: Explanation

Correct Answer: A

- Controls address identified risks
- Appetite defines how much reduction is needed
- Cost is a factor but not the driver

Critical Trap

Controls follow risk, not fashion.

Q64: Overlapping Controls

Question

Two controls address the same risk. This is:

- (A) Always wasteful
- (B) Acceptable if it supports defense in depth and is justified
- (C) Prohibited
- (D) A policy violation

Q64: Explanation

Correct Answer: B

- Overlap can provide redundancy
- Justification should be documented
- Review cost and benefit

Critical Trap

Redundancy can be intentional.

Q65: CSA Limitation

Question

The MAIN limitation of control self-assessment is:

- **A** Possible bias from those assessing their own controls
- **B** It is too slow
- **C** It is not relevant to risk
- **D** It is too costly

Q65: Explanation

Correct Answer: A

- Owners may rate themselves favorably
- Independent validation adds assurance
- CSA still supports engagement

Critical Trap

Self-assessment needs validation.

Q66: KRI Quality

Question

Which is the MOST important characteristic of a good KRI?

- **A** It predicts changes in risk exposure and can be measured
- **B** It is easy to collect
- **C** It is inexpensive
- **D** It never changes

Q66: Explanation

Correct Answer: A

- KRIs should be forward-looking
- Measurability supports thresholds
- Ease and cost are secondary

Critical Trap

A KRI should be predictive and measurable.

Q67: KRI Breach

Question

A KRI exceeds its threshold. What should happen FIRST?

- A. Validate the data, determine the cause and escalate per procedure
- B. Wait for the next cycle
- C. Raise the threshold
- D. Buy new controls immediately

Q67: Explanation

Correct Answer: A

- Confirm the data is accurate
- Understand the cause
- Escalate according to defined procedure
- Raising thresholds hides the signal

Critical Trap

Validate, understand, escalate.

Q68: Executive Reports

Question

Executive risk reports should BEST focus on:

A. Technical detail
B. All raw data
C. Tool configurations
D. Trends, business impact and status against appetite

Q68: Explanation

Correct Answer: D

- Executives need decision-relevant information
- Trends show direction
- Appetite comparison shows what needs action

Critical Trap

Executives need business-level insight.

Q69: Register Updates

Question

The risk register should be updated:

- (A) After audits only
- (B) At project end only
- (C) When risk changes occur and at regular intervals
- (D) Annually only

Q69: Explanation

Correct Answer: C

- Risk is dynamic
- Triggers include changes and incidents
- Periodic review catches drift

Critical Trap

Update on change and on a schedule.

Q70: Continuous Monitoring

Question

Continuous monitoring BEST provides:

- A. Elimination of risk
- B. Lower cost
- C. Timely awareness of changes in risk
- D. Elimination of audits

Q70: Explanation

Correct Answer: C

- It speeds detection
- It supports faster response
- It complements, not replaces, audits

Critical Trap

Continuous monitoring improves timeliness.

Q71: KRI Versus KPI

Question

A KRI differs from a KPI because a KRI:

- **A** Measures achievement of performance goals
- **B** Measures cost only
- **C** Signals changing risk exposure
- **D** Is reported only annually

Q71: Explanation

Correct Answer: C

- KPIs measure performance
- KRIs warn of rising exposure
- Both are metrics but serve different purposes

Critical Trap

KRI warns; KPI measures performance.

Q72: Too Many KRIs

Question

A dashboard has 150 KRIs and nobody acts on them. What is BEST?

- (A) Report less often
- (B) Reduce to a small set of meaningful, actionable indicators
- (C) Remove all indicators
- (D) Add more indicators

Q72: Explanation

Correct Answer: B

- Too many metrics hide the signal
- Focus on key exposures
- Each KRI needs an owner and a response

Critical Trap

Fewer, better indicators.

Q73: All Green

Question

All risk indicators have been green for two years. What should the risk practitioner do?

- A. Cut the risk budget
- B. Validate the thresholds and the quality of the indicators
- C. Stop reporting
- D. Celebrate and reduce monitoring

Q73: Explanation

Correct Answer: B

- Constant green may mean thresholds are too loose
- Indicators may not reflect real exposure
- Validation maintains credibility

Critical Trap

Perpetual green is suspicious.

Q74: Board Reporting

Question

Which is BEST for board risk reporting?

- A. Raw KRI data dumps
- B. An annual list of all risks
- C. Detailed technical logs
- D. Concise, trend-based information linked to risk appetite

Q74: Explanation

Correct Answer: D

- Boards need clarity
- Trends show direction
- Appetite comparison supports oversight

Critical Trap

Concise and appetite-linked.

Q75: Missed Incident

Question

A major incident occurred that no KRI signaled. What should be done?

- A. Remove the KRIs
- B. Ignore it as unforeseeable
- C. Review the KRIs and add or adjust indicators
- D. Assign blame to the monitoring team

Q75: Explanation

Correct Answer: C

- KRIs should help anticipate events
- Gaps indicate missing or weak indicators
- Improve the monitoring framework

Critical Trap

Missed signals mean improve the indicators.

Q76: Register Accuracy

Question

Who should review risk register entries for accuracy?

- A. No one
- B. Auditors only
- C. The risk owners, with facilitation by the risk practitioner
- D. Vendors

Q76: Explanation

Correct Answer: C

- Owners know their risks
- Practitioners facilitate consistency
- Accuracy is an ongoing duty

Critical Trap

Owners keep their entries current.

Q77: Escalation Thresholds

Question

Delayed reporting of significant risks is BEST addressed by:

- A. Annual reminders
- B. Defined escalation thresholds and timelines
- C. More forms
- D. Longer meetings

Q77: Explanation

Correct Answer: B

- Clear triggers speed escalation
- Timelines create accountability
- Reminders alone do not change behavior

Critical Trap

Define when and to whom to escalate.

Q78: KRI Data Source

Question

KRI data is BEST sourced from:

- **A** Self-reports only
- **B** Reliable, preferably automated or independent systems
- **C** Informal conversations
- **D** Estimates from memory

Q78: Explanation

Correct Answer: B

- Reliable data supports decisions
- Automation reduces error
- Independence reduces bias

Critical Trap

Trust data you can verify.

Q79: Audit Findings

Question

How should audit findings be used in risk management?

- **A** As input to update risks and the risk register
- **B** They replace risk assessments
- **C** They should be ignored
- **D** They are only for HR

Q79: Explanation

Correct Answer: A

- Findings reveal control weaknesses
- They inform likelihood and impact
- They complement assessments

Critical Trap

Audit findings are risk inputs.

Q80: Trend Analysis

Question

What is the main value of trend analysis in risk monitoring?

- A. It predicts the exact future
- B. It shows the direction and speed of change in risk
- C. It eliminates risk
- D. It replaces thresholds

Q80: Explanation

Correct Answer: B

- Trends show movement toward or away from appetite
- They support proactive response
- They do not predict certainty

Critical Trap

Trends show where risk is heading.

Q81: BIA Purpose

Question

The PRIMARY purpose of a business impact analysis is to:

A. Test the disaster recovery plan
B. Select backup vendors
C. Determine criticality of processes and recovery requirements
D. Evaluate employee performance

Q81: Explanation

Correct Answer: C

- BIA shows what matters most
- It sets recovery time and point objectives
- Vendor and testing decisions follow

Critical Trap

BIA defines what must be recovered and how fast.

Q82: RTO

Question

The recovery time objective (RTO) is the:

- **A** Target time to restore a process after disruption
- **B** Cost of recovery
- **C** Maximum acceptable data loss
- **D** Maximum tolerable downtime

Q82: Explanation

Correct Answer: A

- RTO is a recovery time target
- RPO is about data loss
- MTD is the absolute limit

Critical Trap

RTO is about time to recover.

Q83: RPO

Question

The recovery point objective (RPO) describes:

- **A** Total downtime
- **B** The maximum acceptable data loss measured in time
- **C** Cost of recovery
- **D** Time to restore service

Q83: Explanation

Correct Answer: B

- RPO sets how far back data can be restored
- It drives backup frequency
- RTO is separate

Critical Trap

RPO is about data loss.

Q84: RTO and MTD

Question

Which relationship is correct?

- A RTO should be longer than MTD
- B RTO and MTD must always be equal
- C They are unrelated
- D RTO should be shorter than the maximum tolerable downtime

Q84: Explanation

Correct Answer: D

- MTD is the point beyond which impact becomes unacceptable
- RTO is a target inside that limit
- RTO beyond MTD defeats the purpose

Critical Trap

RTO sits inside MTD.

Q85: BIA Input

Question

Recovery priorities in a BIA should be determined primarily by:

- (A) Internal audit
- (B) IT staff only
- (C) Business process owners
- (D) Vendors

Q85: Explanation

Correct Answer: C

- Business owners understand impact
- IT validates feasibility
- Priorities reflect business needs

Critical Trap

The business sets priorities; IT delivers.

Q86: Backup Gap

Question

The RPO is 4 hours but backups run nightly. What is the issue?

- A The RTO is too short
- B Backup frequency cannot meet the RPO
- C Backups run too often
- D There is no issue

Q86: Explanation

Correct Answer: B

- Nightly backups can lose up to 24 hours of data
- The RPO requires more frequent recovery points
- Align backup design to RPO

Critical Trap

Backups must match the RPO.

Q87: Failed DR Test

Question

A disaster recovery test restores a system in 10 hours against an RTO of 4 hours. What should happen?

- (A) Ignore the result
- (B) Cancel future tests
- (C) Raise the RTO without review
- (D) Investigate causes, improve the plan and retest

Q87: Explanation

Correct Answer: D

- The plan does not meet the objective
- Root causes must be addressed
- Retesting confirms improvement
- Changing the RTO needs business agreement

Critical Trap

A failed test is a finding, not a formality.

Q88: Vendor Assessment Timing

Question

When should a vendor's risk be assessed?

- A. Only after go-live
- B. After an incident
- C. Never, if the vendor is reputable
- D. Before contract signature and periodically after

Q88: Explanation

Correct Answer: D

- Pre-contract assessment supports negotiation
- Risk changes over time
- Reputation is not an assessment

Critical Trap

Assess before you sign.

Q89: Right to Audit

Question

Which contract provision BEST supports third-party risk oversight?

- A. Right-to-audit and security reporting clauses
- B. A price discount clause
- C. A logo usage clause
- D. A marketing clause

Q89: Explanation

Correct Answer: A

- Oversight needs access to evidence
- Reporting duties provide ongoing visibility
- Commercial terms do not provide assurance

Critical Trap

Contracts must enable oversight.

Q90: Vendor Concentration

Question

Many critical processes depend on one vendor. What is the BEST response?

- A. Increase reliance further
- B. Stop monitoring the vendor
- C. Assess concentration risk and plan alternatives or contingency
- D. Ignore it

Q90: Explanation

Correct Answer: C

- Single dependency creates concentrated exposure
- Alternatives or exit plans reduce impact
- Monitoring should increase

Critical Trap

Concentration is a risk in itself.

Q91: Register Purpose

Question

The main purpose of the risk register is to:

- A. Record and track risks, owners and responses
- B. Replace audits
- C. Store incident tickets
- D. Track project budgets

Q91: Explanation

Correct Answer: A

- It provides a central view of risks
- Owners and responses support accountability
- It supports reporting

Critical Trap

The register supports tracking and accountability.

Q92: Risk Owner Qualities

Question

A risk owner should have:

- A. Technical skills only
- B. Audit independence
- C. Accountability and authority to manage the risk
- D. No decision authority

Q92: Explanation

Correct Answer: C

- Owners make response decisions
- Authority matches accountability
- Technical skills can be supplied by others

Critical Trap

Ownership requires authority.

Q93: Risk Culture

Question

Risk culture is MOST influenced by:

A. The tools used
B. The number of policies
C. Annual training alone
D. The tone and behavior of senior leadership

Q93: Explanation

Correct Answer: D

- People follow what leaders do
- Consistent behavior signals priorities
- Policies and tools do not create culture alone

Critical Trap

Tone at the top shapes culture.

Q94: Three Lines

Question

In the three lines model, who owns and manages risk day to day?

- A Regulators
- B Internal audit
- C The risk function
- D Business and operational management (first line)

Q94: Explanation

Correct Answer: D

- First line owns and manages risk
- Second line oversees and advises
- Third line provides independent assurance

Critical Trap

The first line owns the risk.

Q95: Practitioner Role

Question

The risk practitioner's role in risk acceptance is to:

- **A** Advise and ensure an informed decision by the risk owner
- **B** Accept risk on behalf of the business
- **C** Hide residual risk
- **D** Reject all risk acceptance

Q95: Explanation

Correct Answer: A

- Practitioners provide analysis and advice
- Owners decide
- Decisions should be informed and documented

Critical Trap

Advise; do not decide.

Q96: Emerging Technology

Question

Before adopting an emerging technology, the organization should:

- A. Adopt it widely at once
- B. Perform a risk assessment
- C. Wait for incidents
- D. Always avoid new technology

Q96: Explanation

Correct Answer: B

- New technology brings new risks
- Assessment informs the decision
- Blanket avoidance can hurt the business

Critical Trap

Assess before adopting.

Q97: Assessment Frequency

Question

Risk assessment frequency should BEST be:

- A. Periodic and triggered by significant change
- B. After incidents only
- C. Annual only
- D. During audits only

Q97: Explanation

Correct Answer: A

- Periodic reviews catch drift
- Changes and incidents trigger reassessment
- Annual is a minimum, not a maximum

Critical Trap

Periodic plus event-driven.

Q98: Communicating Risk

Question

Risk should be communicated to non-technical executives in terms of:

- **A** Business impact such as financial, operational and reputational effects
- **B** Technical jargon
- **C** Vulnerability identifiers
- **D** Protocol details

Q98: Explanation

Correct Answer: A

- Executives decide on business terms
- Impact links to objectives
- Technical detail can obscure the message

Critical Trap

Speak the language of the business.

Q99: Stale Register

Question

Many register entries have not been reviewed in over two years. What is BEST?

- **A** Re-validate entries with owners and establish a review cadence
- **B** Leave them as they are
- **C** Increase all ratings
- **D** Delete all entries

Q99: Explanation

Correct Answer: A

- Stale entries may be wrong
- Owners must confirm status
- A cadence prevents recurrence

Critical Trap

Stale registers mislead decisions.

Q100: Unclear Ownership

Question

A risk has no clear owner. What should the risk practitioner do?

- **A** Escalate so that an accountable owner is assigned
- **B** Leave it blank
- **C** Assume IT owns it
- **D** Close the risk

Q100: Explanation

Correct Answer: A

- Unowned risks are unmanaged
- Ownership must be assigned by appropriate authority
- Defaulting to IT confuses accountability

Critical Trap

Every risk needs an owner.

Exam Mindset Summary

Remember

- **FIRST:** understand context and assess before acting
- **Owners decide:** the business owner accepts risk; the practitioner advises
- **Appetite:** compare residual risk to appetite, then escalate or treat
- **Accountability** cannot be outsourced or transferred
- **Monitor:** validate data, trend it, and keep the register current

Good Luck on Your CRISC Exam!